

СОДЕРЖАНИЕ

ВВЕДЕНИЕ.....	3
1 ПРАВИЛА И РОЛИ.....	4
1.1 Правила начисления баллов.....	4
1.2 Роли.....	4
2 ЭТАПЫ ИГРЫ.....	4
2.1 Этап 1 (начальный). Первые признаки.....	4
2.2 Этап 2 (промежуточный). Распространение по сети.....	5
2.3 Этап 3 (промежуточный). Массовое шифрование.....	6
2.4 Этап 4 (промежуточный). Реагирование и восстановление.....	6
2.5 Этап 5 (заключительный). Итоги и выводы.....	7
3 ИТОГИ ИГРЫ.....	8
ЗАКЛЮЧЕНИЕ.....	8
СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ.....	9

ВВЕДЕНИЕ

Цель работы — разработать сценарий деловой игры-квеста по информационной безопасности на основе реального инцидента, принёсшего значительный ущерб. Описать этапы развития ситуации, роли участников и наборы «правильных» решений с начислением баллов, а также исходы игры при разном качестве принятых решений.

Для достижения указанной цели необходимо решение следующих задач:

- выбрать крупный свершившийся инцидент в области информационной безопасности;
- составить сценарий из пяти этапов: начального, трёх промежуточных и заключительного;
- описать роли и наборы решений с начислением баллов;
- показать, как итоговый ущерб зависит от суммы баллов.

За основу взята эпидемия шифровальщика NotPetya (июнь 2017 г.), затронувшая, в частности, логистическую компанию мирового масштаба. Первичное заражение произошло через скомпрометированное обновление доверенного бухгалтерского ПО, после чего вредонос распространился по внутренней сети с использованием уязвимости SMB и кражи учётных данных. Прямой ущерб компании составил порядка 300 млн долларов, глобальный — около 10 млрд. Ситуация удобна для игры: её нельзя купировать одним действием, а итоговый ущерб зависит от цепочки решений.

Игра построена по методике оценки угроз (методический документ ФСТЭК России от 05.02.2021): на каждом этапе определяются возможные негативные последствия, объекты воздействия и способы реализации угрозы, а «правильные» решения опираются на функции и классы защиты.

1 ПРАВИЛА И РОЛИ

1.1 Правила начисления баллов

На каждом этапе команде предлагается три варианта решения. Максимальное решение даёт 3 балла, среднее — 2 балла, минимальное (ошибочное) — 0 баллов. Решение засчитывается только если его может выполнить роль с нужным функционалом; иначе команда должна привлечь другую роль или потратить ход на «обучение». Чем больше суммарный балл, тем меньше итоговый ущерб. Купировать инцидент на первом этапе нельзя: ситуация продолжает развиваться, но грамотные действия снижают потери.

1.2 Роли

Данные приведены ниже (таблица 1).

Таблица 1 – Роли участников и их функционал

Роль	Функционал
Аналитик SOC	Мониторинг событий, корреляция в SIEM, выявление аномалий и индикаторов компрометации
Системный администратор	Управление серверами и сетью, патчи, резервные копии, изоляция сегментов
Специалист по реагированию (IR)	Расследование инцидента, сдерживание, восстановление, форензика
Руководитель ИБ (CISO)	Принятие управленческих решений, приоритеты, взаимодействие с руководством
PR и юрист	Коммуникации, уведомление регуляторов и клиентов, правовые вопросы

2 ЭТАПЫ ИГРЫ

2.1 Этап 1 (начальный). Первые признаки

На нескольких рабочих станциях бухгалтерии после планового обновления ПО появляются перезагрузки и сообщения о «проверке диска». Аналитик SOC видит всплеск сетевой активности по портам SMB. Полный масштаб пока неизвестен (таблица 2).

Таблица 2 – Решения и баллы на этапе 1

Роль	Решение	Баллы
Аналитик SOC / IR	Изолировать подозрительные хосты от сети и передать образцы на анализ, объявить инцидент	3 (максимум)
Системный администратор	Разослать пользователям предупреждение и начать сбор логов, не изолируя хосты	2 (среднее)
Любая роль	Списать перезагрузки на сбой обновления и ничего не предпринимать	0 (ошибка)

При максимальном решении (Аналитик SOC / IR): заражение локализовано на нескольких машинах, у команды есть время подготовить оборону.

При среднем решении (Системный администратор): часть данных для расследования собрана, но вредонос продолжает распространяться.

2.2 Этап 2 (промежуточный). Распространение по сети

Вредонос использует уязвимость SMB и украденные учётные данные администратора, заражая новые хосты. Под угрозой контроллеры домена и файловые серверы (таблица 3).

Таблица 3 – Решения и баллы на этапе 2

Роль	Решение	Баллы
Системный администратор	Экстренно сегментировать сеть, заблокировать SMB между сегментами и отозвать скомпрометированные учётные записи	3 (максимум)
Аналитик SOC	Заблокировать только заражённые хосты по мере их обнаружения	2 (среднее)
Любая роль	Продолжать работу, дожидаться сигнатуры от антивируса	0 (ошибка)

При максимальном решении (Системный администратор): распространение резко замедляется, критичные серверы отрезаны от заражённого сегмента.

При среднем решении (Аналитик SOC): скорость заражения снижается, но домен-контроллеры остаются под угрозой.

2.3 Этап 3 (промежуточный). Массовое шифрование

Значительная часть рабочих станций и серверов зашифрована, останавливаются бизнес-процессы: логистика, документооборот, приём заказов (таблица 4).

Таблица 4 – Решения и баллы на этапе 3

Роль	Решение	Баллы
Руководитель ИБ (CISO)	Ввести план непрерывности бизнеса, перевести критичные процессы на резервную площадку и ручные процедуры	3 (максимум)
Системный администратор	Начать восстановление отдельных серверов из резервных копий без общего плана приоритетов	2 (среднее)
Любая роль	Заплатить выкуп злоумышленникам в надежде на ключ	0 (ошибка)

При максимальном решении (Руководитель ИБ (CISO)): ключевые операции продолжают в деградированном режиме, простой минимизирован.

При среднем решении (Системный администратор): часть сервисов возвращается, но без приоритезации простой затягивается.

2.4 Этап 4 (промежуточный). Реагирование и восстановление

Источник и способ распространения установлены. Нужно вернуть инфраструктуру в строй, не заразив её повторно, и выполнить требования регуляторов (таблица 5).

Таблица 5 – Решения и баллы на этапе 4

Роль	Решение	Баллы
IR + системный администратор	Развернуть чистую инфраструктуру из проверенных резервных копий, установить патчи и сменить все пароли перед подключением	3 (максимум)
Системный администратор	Восстановить системы из копий, отложив смену паролей и патчи на потом	2 (среднее)
Любая роль	Подключать восстановленные машины в старую сеть без проверки	0 (ошибка)

При максимальном решении (IR + системный администратор): восстановление идёт без повторного заражения, доверенная среда воссоздана.

При среднем решении (Системный администратор): сервисы поднимаются быстрее, но остаётся риск повторной компрометации.

2.5 Этап 5 (заключительный). Итоги и выводы

Острая фаза пройдена. Нужно закрыть первопричину, уведомить заинтересованные стороны и извлечь уроки (таблица 6).

Таблица 6 – Решения и баллы на этапе 5

Роль	Решение	Баллы
CISO + PR/юрист	Уведомить регуляторов и клиентов, закрыть уязвимость в цепочке поставок ПО, внедрить сегментацию, MFA и мониторинг цепочки обновлений	3 (максимум)
Системный администратор	Устранить техническую уязвимость, но не выстраивать процессы контроля поставщиков и коммуникаций	2 (среднее)
Любая роль	Вернуться к работе, не разбирая первопричину	0 (ошибка)

При максимальном решении (CISO + PR/юрист): репутационные и правовые риски снижены, повторение инцидента предотвращено.

При среднем решении (Системный администратор): технический риск закрыт, но организационные пробелы остаются.

3 ИТОГИ ИГРЫ

Максимально возможная сумма — 15 баллов (по 3 за каждый из пяти этапов). Итоговый ущерб определяется суммой баллов (таблица 7).

Таблица 7 – Зависимость исхода от набранных баллов

Сумма баллов	Исход
13–15	Инцидент локализован быстро, простой минимален, данные восстановлены, первопричина закрыта — минимальный ущерб
8–12	Инцидент взят под контроль с задержкой, часть процессов простаивала, ущерб умеренный
0–7	Реакция запоздала, произошло массовое шифрование и длительный простой — максимальный ущерб

ЗАКЛЮЧЕНИЕ

В ходе выполнения лабораторной работы были решены следующие задачи:

- выбран крупный свершившийся инцидент в области информационной безопасности;
- составлен сценарий из пяти этапов: начального, трёх промежуточных и заключительного;
- описаны роли и наборы решений с начислением баллов;
- показано, как итоговый ущерб зависит от суммы баллов.

Разработан сценарий деловой игры по информационной безопасности на основе реального инцидента с шифровальщиком NotPetya. Игра состоит из пяти этапов, пяти ролей и наборов решений с начислением баллов. Сценарий показывает ключевую идею: инцидент нельзя остановить одним действием,

но грамотная цепочка решений — своевременная изоляция, сегментация, план непрерывности бизнеса, восстановление из доверенных копий и работа с первопричиной — последовательно снижает итоговый ущерб. Игра закрепляет знания о функциях и классах защиты и о порядке оценки угроз безопасности информации.

Таким образом, все поставленные задачи решены. Цель работы успешно достигнута.

СПИСОК ИСПОЛЬЗОВАННЫХ ИСТОЧНИКОВ

1. Методика оценки угроз безопасности информации : методический документ. — М. : ФСТЭК России, 2021 (утв. 05.02.2021).